

Security+ 2.3 · Buffer Overflows

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.3 — Buffer Overflows (3:37)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: A buffer overflow occurs when an application writes more data than the allocated buffer can hold, overwriting adjacent memory. This can corrupt data, crash the application, or allow an attacker to execute arbitrary code (shellcode). Defenses include bounds checking, DEP (Data Execution Prevention), ASLR (Address Space Layout Randomization), secure coding practices, and compiling with protection mechanisms.

High-Yield Core Concepts Tested on Exam

- Buffer overflow: writing data beyond the allocated buffer size
- Overwrites adjacent memory, potentially leading to code execution
- DEP: prevents code execution from heap/stack memory regions
- ASLR: randomizes memory addresses to hinder exploitation
- Defense: bounds checking, secure coding, compiler protections

Exam Tips & Classic Scenarios

- 'application writes beyond allocated memory' = buffer overflow
- 'randomizes memory addresses' = ASLR
- 'prevents execution from heap/stack' = DEP

Typical Exam Scenario: An application crashes when input longer than expected is sent, indicating a buffer overflow vulnerability that could be exploited.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.3 — Buffer Overflows)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. An attacker enters as a regular user and becomes 'Domain Admin'. This gain of power is:

- A)** Privilege escalation
- B)** Denial of service
- C)** Social engineering
- D)** Sniffing

2. Corporate scenario (Buffer Overflows): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Buffer overflow: writes beyond the buffer size'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Buffer overflow: writes beyond the buffer size...
- D)** Allow shared access among administrators with generic credentials

3. Corporate scenario (Buffer Overflows): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'DEP: blocks execution on heap/stack; ASLR: randomizes addresses'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: DEP: blocks execution on heap/stack; ASLR: randomizes addresses...

4. Corporate scenario (Buffer Overflows): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'application writes beyond allocated memory' = buffer overflow'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to speed up system throughput
- B)** Implement the corresponding solution: 'application writes beyond allocated memory' = buffer overflow...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

5. Corporate scenario (Buffer Overflows): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'randomizes memory addresses' = ASLR.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'randomizes memory addresses' = ASLR.

6. Corporate scenario (Buffer Overflows): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Scenario: 'application crashes when input longer than expected is sent' = buffer overflow (the basis of exploit)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Scenario: 'application crashes when input longer than expected is sent' = buffer overflow (the basis of exploit)
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Buffer Overflows): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Buffer overflow: writes beyond the buffer size'. What is the best recommendation or classification of applicable control?

- A)** Implement the corresponding solution: Buffer overflow: writes beyond the buffer size...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Buffer Overflows): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'DEP: prevents execution on heap/stack; ASLR: randomizes addresses'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: DEP: prevents execution on heap/stack; ASLR: randomizes addresses...

9. Corporate scenario (Buffer Overflows): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'application writes beyond allocated memory' = buffer overflow'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'application writes beyond allocated memory' = buffer overflow...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Buffer Overflows): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'randomizes memory addresses' = ASLR'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'randomizes memory addresses' = ASLR...
- D)** Allow shared access among administrators using generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — Privilege escalation.

✓ **Why it's correct:** Privilege escalation is the technique in which an attacker, after gaining initial access with a regular user, exploits vulnerabilities, misconfigurations, or poorly protected credentials to elevate their permission level within the system. In the context of CompTIA Security+ (SY0-701), this concept is classified as a post-exploitation tactic (TA0004 in MITRE ATT&CK) and can be vertical (from regular user to administrator) or horizontal (from one user to another with similar privileges). The statement describes exactly the transition from 'regular user' to 'Domain Admin', which is the classic example of vertical privilege escalation in Windows Active Directory environments. Therefore, the correct option is the one that identifies this movement as privilege escalation.

✗ **Why the others are wrong:**

- *Denial of service:* Denial of service (DoS) is an attack that aims to make a resource, service, or network unavailable to legitimate users, typically by overwhelming requests, exhausting resources, or exploiting flaws that cause crashes. In the described scenario, the attacker is not trying to take down the service but to gain more power within the domain. DoS does not involve privilege elevation; it affects availability, not the confidentiality or integrity of permissions. Therefore, it does not apply to the gain of power from regular user to Domain Admin.
- *Social engineering:* Social engineering is the psychological manipulation of people to reveal confidential information or perform actions that compromise security, such as clicking malicious links or providing credentials. Although social engineering can be an initial vector to gain access, it does not describe the technical process of privilege elevation within the system. The statement focuses on the gain of power after access, not the initial method of obtaining it. Therefore, social engineering is not the correct classification for the transformation from regular user to Domain Admin.
- *Sniffing:* Sniffing (or eavesdropping) is the passive interception of network traffic to capture sensitive data, such as cleartext credentials or session information. It is an information-gathering technique, not privilege elevation. Even if sniffing could lead to obtaining administrative credentials, it is not the act of escalating privileges itself. The statement describes the end result (becoming Domain Admin), not the method of traffic capture. Therefore, sniffing is not the correct answer to classify the gain of power.

2) C — Implement the corresponding solution: Buffer overflow: writes beyond the buffer size....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Buffer Overflows): Buffer overflow: writes beyond the buffer size.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

3) D — Implement the corresponding solution: DEP: blocks execution on heap/stack; ASLR: randomizes addresses....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Buffer Overflows): DEP: blocks execution on heap/stack; ASLR: randomizes addresses. DEP (Data Execution Prevention) prevents code execution from non-executable memory regions, while ASLR (Address Space Layout Randomization) randomizes memory addresses to make exploitation harder.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) B — Implement the corresponding solution: 'application writes beyond allocated memory' = buffer overflow....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Buffer Overflows): 'application writes beyond allocated memory' = buffer overflow.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to speed up system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) D — Implement the corresponding solution: 'randomizes memory addresses' = ASLR..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Buffer Overflows): 'randomizes memory addresses' = ASLR. Address Space Layout Randomization (ASLR) is a memory protection technique that randomizes the memory addresses used by system and application processes, making it difficult for attackers to reliably predict target addresses for buffer overflow exploits.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual

accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) B — Implement the corresponding solution: Scenario: 'application crashes when input longer than expected is sent' = buffer overflow (the basis of exploit).

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Buffer Overflows): Scenario: 'application crashes when input longer than expected is sent' = buffer overflow (the basis of exploit).

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) A — Implement the corresponding solution: Buffer overflow: writes beyond the buffer size....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Buffer Overflows): Buffer overflow: writes beyond the buffer size.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) D — Implement the corresponding solution: DEP: prevents execution on heap/stack; ASLR: randomizes addresses....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Buffer Overflows): DEP (Data Execution Prevention) prevents code execution in non-executable memory regions (heap/stack), while ASLR (Address Space Layout Randomization) randomizes memory addresses to make exploitation harder. Both are key mitigations against buffer overflow attacks.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) B — Implement the corresponding solution: 'application writes beyond allocated memory' = buffer overflow....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Buffer Overflows): 'application writes beyond allocated memory' = buffer overflow. A buffer overflow occurs when a program writes more data to a buffer than it can hold, potentially overwriting adjacent memory and leading to code execution or crashes. Mitigations include input validation, bounds checking, and using safe programming languages.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) C — Implement the corresponding solution: 'randomizes memory addresses' = ASLR....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Buffer Overflows): 'randomizes memory addresses' = ASLR. Address Space Layout Randomization (ASLR) is a security technique that randomly arranges the address space positions of key data areas of a process, including the base of the executable and the positions of the stack, heap, and libraries. This makes it difficult for an attacker to reliably jump to a specific memory address to execute shellcode after a buffer overflow. ASLR is a preventive control that complements other mitigations like Data Execution Prevention (DEP).

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.